

MGM Resorts ransomware attack

Section 1: Overview of the Breach

❖ What happened?

In september 2023, MGM Resorts, a big casino and hospitality operator that is spread worldwide, was the target to a significant cyberattack that severely impacted its operations and services for a few days. The attack was orchestrated by a hacking group called Scattered Spider, which is believed to be a subgroup of the ALPHV ransomware gang, also referred to as BlackCat.

The attackers used social engineering, specifically voice phishing (vishing), to manipulate the MGM employees into believing that they were speaking with legitimate IT staff. By impersonating internal personnel over the phone, they tricked employees into providing login credentials. After that, the attackers escalated their privileges and gained access to MGM's internal systems. Once inside the system, the attackers extracted sensitive data and deployed ransomware, encrypting parts of MGM's IT infrastructure, which led to days of operational disruption. The customers experienced significant issues as a result of the breach, reporting not being able to check in, unable to pay with a card to book a room or cancel a reservation, unable to access their accounts and, additionally, the main website went down.

MGM Resorts publicly confirmed that customer data has been compromised, potentially including names, contact details, gender, birth dates and driver's license numbers. For some guests, sensitive information such as Social Security numbers and passport details were also exposed. While MGM assured the public that there was no evidence of widespread exploitation of the stolen data for identity theft or fraud, they encouraged the affected customers to take advantage of credit monitoring and fraud alert services.

The breach caused significant financial and reputational damage to MGM. The company reported a \$100 million loss in third-quarter 2023 and faced investigations by the FBI and Nevada Gaming Control Board. Customer trust declined, and class action lawsuits was filed. MGM responded by investing \$50 million in cybersecurity improvements.

❖ Timeline

- **September 7:** Scattered Spider targets an IT support vendor of Caesar's Entertainment, receiving half of the \$30 million ransom. This group is later linked to the MGM cyberattack.
- **September 11:** MGM acknowledges a "cybersecurity incident" affecting its systems and starts an investigation.
- **September 12:** MGM reports that most services, including resorts and entertainment, remain operational, but customers face issues with online bookings and the website.
- **September 13:** VX Underground links the attack to vishing and the ALPHV ransomware gang. Scattered Spider is confirmed as the hacker group.

- **September 13:** Moody's warns of potential credit impacts and risks due to MGM's technology reliance.
- **September 18:** Experts suggest a collaboration between ALPHV and Scattered Spider. Okta confirms multiple clients, including MGM, were targeted by these groups.

Section 2: Security Failures and Vulnerabilities

❖ Root cause analysis

1. **MFA Fatigue:** at the end of 2023 it was discovered that Scattered Spider used MFA fatigue tactics, sending prompts to employees to approve until they accidentally granted permission
2. **Insufficient employee training:** employees were not well enough trained to avoid being tricked into sharing their login credentials over the phone
3. **Insufficient control measures:** attackers were able to easily exploit privileges and access sensitive data in the infrastructure

❖ Audit relevance

An IT audit could have found these security issues by checking how well multi-factor authentication works and looking for weaknesses related to fatigue tactics. Regular checks on employee training would have shown where people didn't understand social engineering risks, making everyone more prepared. Audits of access management systems could have found problems with privilege escalation, giving chances to improve security. Also, a full infrastructure audit could have spotted mistakes or missed security issues in the IT setup, possibly stopping the breach.

Section 3: Regulatory and Legal Implications

❖ Regulations impacted:

- **General Data Protection Regulation (GDPR):** MGM Resorts, which manages personal data including sensitive details like Social Security numbers and passports, is likely governed by GDPR. The data breach, which exposed this information, may breach GDPR rules on data security and breach notification. If any affected individuals were in the EU or UK, MGM could face substantial fines for not protecting their data or for failing to notify them within the required 72-hour window.
- **California Consumer Privacy Act (CCPA):** Since MGM Resorts likely serves residents of California, it must comply with CCPA. The breach may have impacted California consumers, and if MGM did not promptly notify them or take necessary actions, it could face penalties under this regulation.
- **Payment Card Industry Data Security Standard (PCI DSS):** If payment card data was compromised during the attack, MGM might be in violation of PCI DSS. This standard

requires businesses to secure cardholder data. Failure to comply with PCI DSS could result in penalties and increased oversight.

- **Nevada Data Breach Notification Law:** As MGM operates in Nevada, it must follow state-specific laws on breach notification. These laws require timely notification to affected individuals. Non-compliance could lead to legal and regulatory consequences for MGM.

❖ Consequences:

- **Fines and penalties:** MGM Resorts might incur significant fines for violating various data protection laws, including the General Data Protection Regulation (GDPR), California Consumer Privacy Act (CCPA), and Payment Card Industry Data Security Standard (PCI DSS). The failure to secure personal and payment data could lead to penalties, depending on the severity of the violation and the jurisdiction involved.
- **Legal actions:** MGM could face multiple lawsuits from affected individuals and class actions. These lawsuits claim that the company did not adequately protect customer data, potentially resulting in settlements, legal fees, and ongoing litigation expenses.
- **Reputation impact:** The breach has significantly damaged MGM's reputation, as customers have lost trust in the company's ability to protect their personal information. This loss of confidence can lead to decreased customer retention, reduced sales, and a negative public perception of the brand.
- **Enhanced regulatory oversight:** In addition to ongoing investigations, MGM may face increased regulatory scrutiny and compliance audits. Regulatory bodies might enforce stricter data protection measures, leading to more oversight and potential disruptions in operations.

Section 4: Recommendations and Lessons Learned

❖ Proposed improvements:

- **Advanced Multi-Factor Authentication (MFA) and Adaptive Security:** The breach was significantly influenced by MFA fatigue tactics. MGM should upgrade its MFA system by incorporating more sophisticated methods like adaptive authentication, which uses contextual data to decide when MFA is necessary. Implementing time-based authentication limits or biometric verification can also reduce risks associated with user fatigue and enhance overall security.
- **Comprehensive Security Awareness Training:** Employees require continuous training to identify social engineering tactics, particularly phishing, vishing, and other impersonation methods. MGM should establish more robust training programs that include simulated attack scenarios, regular refresher courses, and periodic phishing tests. This will help employees better recognize suspicious activities and understand the importance of protecting sensitive information.

- **Strengthened Privilege and Access Management:** The breach was partly due to attackers easily escalating privileges and accessing sensitive data. MGM should review and enforce the principle of least privilege (POLP), ensuring users have only the necessary access to systems and data for their roles. Regular audits of user permissions, along with automated tools to detect and prevent privilege escalation, would help minimize unauthorized access risks.

❖ Audit frameworks:

- **COBIT:** COBIT offers a structured approach to evaluate the effectiveness of IT governance and security controls. By implementing COBIT, MGM could have identified gaps in their access management policies, MFA deployment, and incident response procedures, allowing them to address vulnerabilities proactively before an attack.
- **ISO 27001:** ISO 27001 provides a framework for establishing, implementing, and maintaining an information security management system (ISMS). Regular audits based on ISO 27001 standards would have enabled MGM to systematically review their security policies, identify infrastructure weaknesses, and ensure compliance with global data protection regulations, thereby preventing data breaches and mitigating the impact of any incidents.
- **NIST:** NIST's cybersecurity framework could have guided MGM in identifying and managing IT infrastructure risks. The framework emphasizes continuous monitoring, risk management, and incident response, which are crucial for early detection of vulnerabilities and reducing the impact of cyberattacks.

Section 5: Personal Reflection & Critical Thinking

❖ Application to IT audit:

The MGM Resorts breach showed me how important IT audits are in finding security weaknesses. It made me realize that regularly checking things like multi-factor authentication (MFA), employee training, and access controls is crucial. As an IT auditor, I would focus on making sure MFA systems work well and that employees know how to spot tricks like phishing and vishing. I would also check that employees only have access to the data they need for their jobs. In my own organization, I would do regular audits, test security systems, and educate employees to prevent similar breaches.

❖ Critical Thinking Statement:

What surprised me most was how effective social engineering attacks like vishing can be. The hackers used MFA fatigue, showing how easily people can make mistakes when constantly asked to approve security prompts. It was hard to find detailed information about how the attack happened. This made me see how important it is to have systems that can quickly detect and respond to attacks. This assignment taught me how cybersecurity and auditing are linked and why security measures need to be constantly checked and updated.

❖ Red Flags and Recommendations:

If I were the IT auditor at MGM Resorts before the breach, I would have looked for a few key issues. First, I would check if their MFA system was weak against fatigue tactics and if employees were trained to spot phishing and vishing attempts. I would also make sure employees only had access to the data they needed. If I found problems, I would recommend improving the MFA system, providing better training for employees, and making access controls stricter. These steps would help prevent a breach and protect sensitive data.

Bibliography

- ★ Ahern, Brian. "MGM Resorts Update on Recent Cybersecurity Issue." MGM Resorts Investors, <https://investors.mgmresorts.com/investors/news-releases/press-release-details/2023/MGM-RESORTS-UPDATE-ON-RECENT-CYBERSECURITY-ISSUE/default.aspx>.
- ★ Braithwaite, Sarah. "ALPHV: Hackers Reveal Details of MGM Cyber Attack." West Oahu Hawaii, <https://westoahu.hawaii.edu/cyber/global-weekly-exec-summary/alphv-hackers-reveal-details-of-mgm-cyber-attack>.
- ★ Gomez, Fatima. Cyber Attack & Breach on the MGM Resort Explained. Inszone Insurance, <https://inszoneinsurance.com/blog/cyberattack-mgm-resort-explained>.
- ★ Greig, Jonathan. "MGM Agrees to Pay \$45 Million to Victims of 2019 Data Breach and 2023 Ransomware Attack." The Record, <https://therecord.media/mgm-agrees-45-million-payment-data-breach-ransomware-victim> S.
- ★ Gupta, Satya. "In-Depth Analysis of the 2023 MGM Resorts Cyberattack." Virsec Systems Blog, <https://industrial-software.com/community/news/in-depth-analysis-of-the-2023-mgm-resorts-cyberattack-virsec-systems-blog>.
- ★ Powell, Olivia. "A Full Timeline of the MGM Resorts Cyber Attack." CS Hub, <https://www.cshub.com/attacks/news/a-full-timeline-of-the-mgm-resorts-cyber-attack>.